

Content Security Policy (CSP) Specification & Enforcement

Document ID: DOC-SEC-002
Classification: Official
System: Case Ace v2.0 (Citizens Advice Wandsworth)
Standard Alignment: ISO/IEC 27001:2022 A.8.20 (Network security), A.8.26 (Application security requirements), ISO/IEC 27701:2019

1. Objective & Security Posture

The Content Security Policy (CSP) for Case Ace v2.0 is designed to enforce the strictest possible boundary:

Zero untrusted code execution: Complete prohibition of unsafe-inline scripts and styles.

Zero third-party data leakage: Complete elimination of external font CDNs, analytics providers, error trackers, and unapproved origins.

Tightly scoped networking: Strict connect-src allowlists pinned to europe-west2 backend and cloud service endpoints.

Controlled WebAssembly execution: Scope wasm-unsafe-eval solely for local, on-device ASR and NER model weights (WASM/WebGPU).

2. Directives Matrix

3. Environment-Specific connect-src Allowlist

4. Complementary Security Headers

Every response from the backend and static web server includes:

```
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer
Permissions-Policy: camera=(), geolocation=(), payment=(), usb=(), display-capture=(),
microphone=(self)
```